

ROP Chain

Bối cảnh (Context)

Hệ thống bảo mật tiên tiến đã bật tính năng NX/DEP (Non-Executable Stack). Dù bạn có khai thác được lỗi tràn bộ đệm để đưa mã độc (shellcode) vào Stack, hệ điều hành cũng sẽ từ chối thực thi bất kỳ đoạn mã nào nằm ở đó và đóng băng chương trình.

Hệ thống quá vững chãi? Không hẳn, các lệnh Assembly có sẵn của chính chương trình thì vẫn được phép chạy cơ mà.

Mục tiêu (Objective)

- **Nhiệm vụ:** Khai thác Buffer Overflow để lấy được quyền Shell (`/bin/sh`) mà không cần chèn shellcode lên Stack.
- **Vấn đề / Lỗi hỏng: Return-Oriented Programming (ROP).** Kẻ tấn công ghi đè Stack bằng một chuỗi các địa chỉ, trỏ tới các đoạn lệnh Assembly ngắn có sẵn trong chương trình (gọi là "gadgets"), thường kết thúc bằng lệnh `ret` . Việc sắp xếp các gadget này một cách khéo léo giúp kẻ tấn công ráp các mảnh ghép lại để tự động đưa tham số vào thanh ghi và gọi hàm hệ thống như `execve` hoặc `system` .
- **Flag:** Mở được terminal (Shell) trên máy chủ.

Gợi ý (Hints)

- Sử dụng công cụ `ROPgadget` hoặc `ropper` để tìm kiếm các gadget (ví dụ `pop rdi; ret`).
- Cấu trúc chuỗi khai thác: `Padding + Address of Pop RDI + Address of "/bin/sh" string + Address of system()` .